

Document: auditq_upload.pdf
Generated: 13 June 2026 09:07
Model: Qwen/Qwen2.5-7B-Instruct
Embeddings: BAAI/bge-small-en-v1.5 | FAISS IndexFlatIP

75.0%

MEDIUM

OVERALL COMPLIANCE SCORE

75.0%

Risk Level: MEDIUM | Rules Checked: 13 | Tokens: 7368 | Avg Latency: 17.48s/chunk

COMPLIANCE SCORE BY FRAMEWORK

GDPR		75.0%
SOX		40.0%
HIPAA		57.1%
PCI DSS		100.0%
Insurance Compliance		100.0%

VALIDATION STATUS SUMMARY

8

COMPLIANT

2

NON COMPLIANT

3

PARTIAL

0

NOT APPLICABLE

DETAILED COMPLIANCE FINDINGS (deduplicated - one result per rule)

GDPR

GDPR-002

PART

HIGH

70%

[Sec.~1]

While interim retention periods are mentioned, a formal, documented data retention schedule has not been approved.

Evidence: The Company acknowledges that a comprehensive, documented data retention schedule covering all data categories has not yet been formally approved by the Data Protection Officer.

Gap: A formal, documented data retention schedule has not been approved.

Action: Formalize and document the data retention schedule for all data categories.

GDPR-005

PART

MEDIUM

79%

[Sec.~2]

While most third-party agreements are compliant, some are not yet in place.

Evidence: "Data Processing Agreements (DPAs) compliant with Article 28 of GDPR have been executed with 39 of these processors. Eight processors, primarily recent onboarding during Q4 2025, do not yet have executed DPAs in place."

Gap: Eight third-party processors do not yet have GDPR-compliant Data Processing Agreements in place.

Action: Ensure all third-party processors sign GDPR-compliant Data Processing Agreements by Q2 2026.

GDPR-004

PASS

CRITICAL

91%

[Sec.~2]

The document explicitly states the 72-hour reporting timeline.

Evidence: "the Company will assess the risk to data subjects and notify the relevant supervisory authority (ICO in the UK) within 72 hours"

SOX

SOX-003

PASS

HIGH

91%

[Sec.~3]

The document explicitly states a 7-year retention period for financial records.

Evidence: "All financial records, general ledger entries, accounts payable and receivable records, bank reconciliations, audit workpapers, and supporting documentation are retained for a minimum period of 7 years"

SOX-001

FAIL

CRITICAL

70%

[Sec.~2]

The ICFR framework is not fully documented, indicating a material weakness.

Evidence: "Management acknowledges that formally documented Internal Controls over Financial Reporting (ICFR) as required under Section 404 of the Sarbanes-Oxley Act have not been comprehensively documented for the current fiscal year"

Gap: The ICFR framework is not fully documented, including control objectives, control activities, risk assessments, and monitoring activities.

Action: Complete the ICFR framework documentation by Q3 2026.

HIPAA

HIPAA-004

PART

HIGH

73%

[Sec.~4]

Audit logging is partially implemented but not fully for all systems containing PHI.

Evidence: Audit logs are in place for the primary Workday HR system, however three legacy occupational health record systems acquired through the 2023 merger with MedCorp Solutions do not currently generate HIPAA-compliant audit logs.

Gap: Audit logging is not in place for three legacy occupational health record systems.

Action: Implement HIPAA-compliant audit logging for the three legacy occupational health record systems.

HIPAA-003

PASS

CRITICAL

88%

[Sec.~3]

Evidence: "In the event of a breach of unsecured PHI, the Company will notify affected individuals without unreasonable delay and within 60 days"

HIPAA-005

FAIL

HIGH

65%

[Sec. ~4]

Business Associate Agreements are not in place with two recently onboarded employee assistance programme providers.

Evidence: The Company maintains a register of all Business Associates updated quarterly. However, BAAs have not been executed with two recently onboarded employee assistance programme providers who may have access to PHI.

Gap: BAAs are not in place with two recently onboarded employee assistance programme providers.

Action: Execute signed BAAs with the two recently onboarded employee assistance programme providers.

PCI DSS

PCI-003

PASS

HIGH

86%

[Sec. ~5]

The document explicitly mentions the use of a firewall and network segmentation.

Evidence: The cardholder data environment is segregated from the corporate network and public internet using a dedicated next-generation firewall (Palo Alto Networks PA-5220) with application-aware filtering. Network segmentation is enforced through ...

PCI-002

PASS

HIGH

86%

[Sec. ~5]

The document explicitly states that access is restricted based on job roles and the principle of least privilege.

Evidence: Access rights to payment processing systems have not been formally reviewed following the organisational restructuring in Q1 2026. Twelve individuals retain access rights to payment system administration consoles that may no longer be requi...

PCI-004

PASS

HIGH

84%

[Sec. ~5]

The document describes regular vulnerability scans and penetration testing procedures.

Evidence: The Company conducts quarterly internal and external vulnerability scans of all systems in scope for PCI-DSS using Qualys Enterprise. Critical and high vulnerabilities are remediated within 30 and 60 days respectively. Annual penetration te...

Insurance Compliance

INS-003

PASS

CRITICAL

87%

[Sec. ~6]

The document explicitly mentions AML and KYC procedures.

Evidence: "The Company operates a risk-based AML programme compliant with the Money Laundering, Terrorist Financing and Transfer of Funds Regulations 2017."

INS-004

PASS

CRITICAL

86%

[Sec. ~6]

The document explicitly states the company's adherence to Solvency II Directive and maintains significant SCR and MCR ratios.

Evidence: "The Solvency Capital Requirement (SCR) coverage ratio as at 31 December 2025 was 187%, significantly above the 100% minimum requirement. The Minimum Capital Requirement (MCR) coverage ratio was 312%."

RISK-RANKED REMEDIATION ACTION PLAN

Issues ranked by severity. Address CRITICAL immediately, HIGH within 30 days, MEDIUM within 90 days.

1	SOX-001	SOX	CRITICAL	NON COMPLIANT	Gap: The ICFR framework is not fully documented, including control objectives, control activities, risk assessments, and monitoring activities. Action: Complete the ICFR framework documentation by Q3 2026.
2	GDPR-002	GDPR	HIGH	PARTIAL	Gap: A formal, documented data retention schedule has not been approved. Action: Formalize and document the data retention schedule for all data categories.
3	HIPAA-004	HIPAA	HIGH	PARTIAL	Gap: Audit logging is not in place for three legacy occupational health record systems. Action: Implement HIPAA-compliant audit logging for the three legacy occupational health record systems.
4	HIPAA-005	HIPAA	HIGH	NON COMPLIANT	Gap: BAAs are not in place with two recently onboarded employee assistance programme providers. Action: Execute signed BAAs with the two recently onboarded employee assistance programme providers.
5	GDPR-005	GDPR	MEDIUM	PARTIAL	Gap: Eight third-party processors do not yet have GDPR-compliant Data Processing Agreements in place. Action: Ensure all third-party processors sign GDPR-compliant Data Processing Agreements by Q2 2026.

APPENDIX A - COMPLIANCE SCORING METHODOLOGY

auditq uses a weighted scoring model to calculate compliance scores. Each rule is evaluated once per document (deduplicated across all chunks). The overall score reflects a severity-weighted average of all rule outcomes.

1. Severity Weights

Severity	Weight	Rationale
CRITICAL	3x	Regulatory breach risk, immediate business impact
HIGH	2x	Significant compliance gap, near-term remediation needed
MEDIUM	1x	Process improvement required, lower immediate risk

2. Status Score Values

Status	Score	Meaning
COMPLIANT	1.0	All required clauses explicitly present
PARTIAL	0.5	Some requirements met, gaps identified
NON_COMPLIANT	0.0	Required clauses absent or contradicted
NOT_APPLICABLE	N/A	Rule not relevant to this document type

3. Score Calculation Formula

Framework Score = $\text{sum}(\text{status_score} \times \text{severity_weight}) / \text{sum}(\text{severity_weight}) \times 100$

Overall Score = weighted average of all framework scores

NOT_APPLICABLE rules are excluded from score calculation entirely.

4. Confidence Score Calculation (Blended)

Confidence scores are not purely LLM-generated opinions. auditq blends two independent signals to produce a more reliable confidence estimate:

Confidence = $(0.6 \times \text{LLM self-score}) + (0.4 \times \text{Retrieval Similarity} \times 100)$

- LLM self-score: Qwen2.5-7B assessment of evidence strength (0-100)
- Retrieval Similarity: FAISS cosine similarity between document chunk and rule embedding
- Rules below 0.60 similarity threshold are excluded entirely to reduce false positives

5. Rule Deduplication

Documents are split into overlapping chunks for processing. The same rule may be evaluated across multiple chunks. auditq deduplicates by rule_id before scoring, retaining the most critical finding per rule: NON_COMPLIANT > PARTIAL > COMPLIANT > NOT_APPLICABLE. This ensures each control appears exactly once in the report.